

Tier 1 Access Model

Who may do what to the triage agent and the alerts it handles — the roles that exist today, the two that do not yet, and what Tier 3 and the SOC Manager should be given.

THE PRINCIPLE

Authority is enforced by the server, never by the interface. A role that may not do something is refused at the API even if someone bypasses the screen entirely. Hiding a button is a usability choice; refusing the request is the control.

Two more rules shape everything below. First, **the agent is a principal too** — it holds credentials, and what it must *not* be able to do matters more than what it can. The playbook is explicit that this is a permission, not a written instruction.

Second, **the person who widens the agent's autonomy must not also control what it learns or what the accuracy figures say.** That separation is most of the reason this document has more than three roles in it.

The roles

Six principals. Two are implemented in the console today.

MACHINE IDENTITY

The triage agent

Does the Tier 1 job. Reads alerts and enrichment, writes dispositions, and may take three pre-approved reversible actions.

IMPLEMENTED

HUMAN · INVESTIGATES

Tier 2 Analyst

Picks up escalations that arrive already enriched and explained. Investigates and resolves; does not triage.

IMPLEMENTED

HUMAN · ROTATING DUTY

AI Supervisor

Checks the agent's work. Decides held alerts, reviews sampled closures, and teaches it when it is wrong.

IMPLEMENTED

HUMAN • RESPONDS

Tier 3 / Incident Response

Takes the incidents that bypass Tier 1 entirely. Containment rights exist only inside a declared incident and expire with it.

NOT IMPLEMENTED

HUMAN • OWNS THE RISK

SOC Manager

Owens autonomy, the kill switches and the thresholds. Accepts the residual risk of letting the agent close alerts.

NOT IMPLEMENTED

HUMAN • OWNS THE AGENT

Security Administrator

Decides what the agent learns, and holds its credentials. Deliberately separate from the people who operate it.

NOT IMPLEMENTED

Two more sit outside the agent's own access model but appear in the matrix because they hold rights nobody in the SOC should: **Detection Engineering** owns rule edits, exceptions and suppressions — Tier 1 proposes tuning and never applies it — and **Audit / Risk** holds read-only access to the audit trail and evidence packs.

The permission matrix

Grouped by what the permission is for. Read a row as "may this role do this?"

✓ Allowed ▲ Bounded — allowed only inside a stated condition, never standing – Refused

CASES AND EVIDENCE							
CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC	ADMIN
Read an alert and its enrichment	✓	✓	✓	✓	✓	–	
Read a case and its full 16-section package	✓	✓	✓	✓	✓	–	
See the agent's reasoning chain	✓	–	✓	✓	✓	✓	
Run or re-run triage on an alert	✓	–	✓	–	–	–	
Export an evidence pack	–	✓	✓	✓	✓	✓	
DECISIONS ON ALERTS							
CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC	ADMIN
Close an alert with no human involved	✓	–	–	–	–	–	
Escalate, or hold for a person	✓	–	✓	–	–	–	
Decide a held alert — close it or send it up	–	–	✓	–	–	–	
Review a sampled closure: correct or wrong	–	–	✓	–	–	–	
Override a verdict already recorded	–	–	✓	–	–	–	
RESPONSE ACTIONS							
CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC	ADMIN
Pre-approved low-risk actions — soft-delete mail, quarantine an attachment, block an indicator	✓	✓	✓	✓	–	–	
Approve high-impact containment	–	–	–	▲	–	–	
Isolate a host	–	–	–	▲	–	–	
Disable an account, reset credentials, revoke sessions	–	–	–	▲	–	–	
Contain a Tier-0 asset, a VIP or a business-critical service	–	–	–	▲	–	–	
Declare an incident and invoke the IR process	–	–	–	✓	✓	–	
Suspend Tier 3's standing containment authority	–	–	–	–	✓	–	
WHAT THE AGENT LEARNS							
CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC	ADMIN

CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC ADMIN
Submit a candidate lesson	—	✓	✓	✓	✓	—
Approve or reject a lesson	—	—	—	—	—	✓
Reverse a lesson already in use	—	—	—	—	▲	✓
Hold the agent's own credentials	—	—	—	—	—	✓

GOVERNANCE, TUNING AND AUDIT

CAPABILITY	AGENT	TIER 2	SUPERVISOR	TIER 3	SOC MGR	SEC ADMIN
Change a wave's autonomy — shadow, supervised, autonomous	—	—	—	—	✓	—
Use a kill switch, per wave or global	—	—	—	—	✓	—
Turn autonomous actions off entirely	—	—	—	—	✓	—
Change the confidence threshold to act alone	—	—	—	—	✓	—
Change the closure review sample rate	—	—	—	—	✓	—
Grant a wave autonomy at a gate	—	—	—	—	✓	—
Waive a gate criterion	—	—	—	—	—	—
Accept the residual risk of the capability	—	—	—	—	✓	—
Edit, disable or add an exception to a detection rule	—	—	—	—	—	—
Propose tuning to detection engineering	✓	✓	✓	✓	✓	—
Read the audit log	—	▲	✓	✓	✓	✓
Edit or delete an audit entry	—	—	—	—	—	—

Two rows are refused to *everyone*, and that is the point of them. Nobody waives a gate criterion — a criterion that can be waived is not a gate. Nobody edits the audit log, including the people who own the system, or it is not evidence. Rule edits sit with detection engineering, outside every role here; Tier 1 proposes tuning and never applies it.

Two capabilities are absent from this matrix on purpose. Once a case is escalated, **nobody may take it from the analyst holding it** — not a supervisor, not Tier 3, not the manager. An analyst mid-investigation is the worst possible person to interrupt, and a case that genuinely needs different hands is a new incident, declared as one. And **a closed case is not reopened**: the disposition and its reasoning stand as the record of what was decided and why. Work that needs doing again arrives as a new alert or a new incident, which keeps the original decision auditable instead of editable.

What Tier 3 should have

Tier 3 is already assumed by the playbook — class C incidents bypass Tier 1 and go straight to Tier 2 or Tier 3, and multi-host lateral movement is called a Tier 3 candidate — but it holds no permissions anywhere in the system today.

THE BOUND THAT MAKES THIS SAFE

Tier 3 holds no standing power over the estate. Every containment right below is unlocked by a **declared incident** and expires when it closes. Declaring is itself logged, notifies the SOC Manager immediately, and is reviewed afterwards. Outside a declaration, Tier 3 has an investigator's read access and nothing more.

Tier 3 / Incident Response

Scoped to one job: investigate and contain the incidents that exceed Tier 2. Not a senior analyst with extra buttons.

ADD ON TOP OF TIER 2, AND ONLY THIS

- + **Declare an incident.** The one unconditional addition, because a declaration is what unlocks everything else — and it is visible the moment it happens.
- + **Containment inside a declared incident** — isolate a host, disable an account, revoke sessions, on the entities named in that incident. Not estate-wide, and not outside it.
- + **See the agent's reasoning**, because Tier 3 is often deciding whether the agent's blind spot caused the incident.
- + **Submit lessons** — the same right every analyst has.

DELIBERATELY WITHHELD

- × **Containment outside a declared incident.** If it is worth isolating a host, it is worth declaring.
- × **Unilateral containment of a Tier-0 asset, a VIP or a business-critical service.** A second responder approves, even mid-incident. The blast radius of a wrong isolation there is the service itself.
- × **Deciding held alerts and reviewing the agent's closures.** That is the AI Supervisor's duty. Tier 3 investigates incidents; it does not also mark the agent's homework.
- × **Running or re-running triage.** Not needed to do the job.
- × **Overriding a recorded verdict.** Changing what the agent concluded is the AI Supervisor's duty. Tier 3 records what it found on its own incident instead.
- × **Taking a case from Tier 2.** Nobody may move a case once it is escalated — see below.
- × **Reopening a closed case.** Closed is closed. A case that needs looking at again arrives as a new alert or a new incident.
- × Approving a lesson, including their own
- × Anything governance — autonomy, thresholds, kill switches, sample rate
- × Editing a detection rule, or the audit log

Tier 3 is not senior to the SOC Manager. It is easy to read a role that can isolate a domain controller as outranking one that cannot, but they are different kinds of authority. Tier 3 holds **operational** power, narrow and time-boxed: specific entities, inside a declaration, for the life of one incident, every action logged and reviewed afterwards. The SOC Manager holds **standing** authority over the system itself — what the agent is allowed to do at all, how much of its work is checked, whether a wave is trusted, and who carries the risk if it is wrong. The manager also sets the conditions Tier 3 operates under and can suspend its standing containment authority outright.

A useful test: Tier 3 can act on *this incident*. The SOC Manager decides what happens to *every future alert*. The second is the greater power, and it is the one that needs change control.

What the SOC Manager should have

The console already refuses autonomy changes with "SOC Manager authority, via change control" — but no role holds that permission, so the refusal currently applies to everyone.

SOC Manager

Owns the risk appetite of the capability. Reads everything; disposes of nothing.

SHOULD HOLD

- + **Per-wave autonomy** — moving a wave between shadow, supervised and autonomous, through change control rather than a toggle.
- + **Kill switches**, per wave and global, usable immediately and without change control. A control you have to raise a ticket for is not a kill switch.
- + **The actions-enabled switch** and the **confidence threshold**.
- + **The closure review sample rate** — how much of the agent's work gets checked.
- + **Granting a wave autonomy at its gate**, including enforcing the per-family false-negative rule so a weak alert family cannot ride through on its wave's average.
- + **Accepting the residual risk**. The playbook's own open item 10 says nobody is named for this. An autonomous close is a risk acceptance and it needs an owner.
- + **Setting the conditions Tier 3 operates under**, and suspending its standing containment authority outright. Tier 3 acts inside a boundary the manager draws.
- + **Reviewing every incident declaration after the fact** — what was contained, on whose authority, and whether it was proportionate.
- + Full read access to metrics, the audit log and every case.

SHOULD NOT HOLD

- × **Approving lessons**. See below — this is the one recommendation here that differs from the obvious reading of the authority matrix.
- × **Waiving a gate criterion**. Gates are met or the wave waits.
- × **Disposing of alerts** — closing, escalating or reviewing. A manager clearing their own team's backlog is how the accuracy numbers stop meaning anything.
- × Editing detection rules, or the audit log.
- × Transferring accountability for the residual risk to the vendor, the agent or the team.

Why the SOC Manager should not approve lessons. Reading the authority matrix as "the manager can do everything the others can, plus governance" puts the autonomy dial and the agent's learning in one pair of hands. That person could then loosen a gate and approve the lessons that shape the behaviour the gate measures. Keeping lesson approval with a Security Administrator costs one extra name on a rota and removes the single most useful thing an insider — or an honestly over-optimistic manager — could do to this system.

Pairs that must never sit with one person

If your rota puts both sides of any of these on the same name, the control on the right stops working.

Change a wave's autonomy

NEVER BOTH

Approve what the agent learns

One person could loosen the gate and shape the behaviour the gate measures.

Submit a lesson

NEVER BOTH

Approve that lesson

Already the design: an analyst submits, a named administrator decides. This is the whole of the learning control.

Review closures for accuracy

NEVER BOTH

Set the sample rate for reviews

Whoever is measured must not choose how much of their work gets measured.

Triage an alert

NEVER BOTH

Tune the rule that raised it

The playbook's own line: Tier 1 proposes tuning, detection engineering decides. Otherwise a noisy rule gets silenced by the person it annoys.

Operate the agent day to day

NEVER BOTH

Hold the agent's credentials

Otherwise the permission boundary below is a written instruction rather than a control.

Accept the residual risk

NEVER BOTH

Be the only source of the accuracy figures

The audit trail and the false-negative count must be independently readable by Audit / Risk.

The agent's own credentials

The section most access models forget. The playbook is explicit that these are permissions, not written instructions — the agent must not *hold* a credential that permits them.

THE AGENT MUST HOLD

- + Read on security-category incidents in active status, and their raw triggering events
- + Read on the five enrichment sources: identity and HR, asset inventory, threat intelligence, twelve months of history, behavioural baselines

THE AGENT MUST NOT HOLD

- ✗ Edit a rule, create a rule exception, create an event-dropping rule, disable a rule, or create a remediation action
- ✗ Isolate a host, disable an account, reset credentials or revoke sessions

- + Write on the disposition fields of an incident it triaged — resolution, status, cleared reason, comments, tag — and create a case assigned to Tier 2
- + Execute on exactly three actions, each reversible and single-entity: soft-delete a confirmed malicious mail, quarantine a confirmed malicious attachment, submit a confirmed indicator to the block list
- + Append-only write to the audit log
- × Approve any lesson, including one derived from its own mistake
- × Change its own autonomy, threshold or kill switch
- × Edit or delete anything already written to the audit log
- × Any write access to the HR or legal-hold register — it reads the flag and nothing more
- × Any credential that survives the kill switch being used

Test the last one deliberately. A kill switch that stops the agent being invoked, while leaving its API token valid, stops the workflow and not the capability. Confirm the token is revoked or scoped to nothing, not merely that the queue stopped feeding it.

What the code actually enforces today

The gap between this document and the running system, stated plainly so nobody assumes the matrix above is live.

ENDPOINT	PERMISSION CHECKED	EFFECT
POST /api/state (autonomy, kill switch, actions)	config	Refused for every role — nobody holds it
POST /api/review	review	Supervisor only. Working as designed
POST /api/lesson	lessonApprove	Refused for every role — nobody holds it
POST /api/override	none	The override permission is declared on both roles and never checked
POST /api/reset	none	Any caller can wipe every case, lesson and audit entry
POST /api/alerts	none	Any caller can inject an alert into the stream
GET /api/audit · /api/metrics · /api/evidence-pack · /api/bootstrap	none	All readable by any caller, unscoped

There is no authentication. The role arrives in the request body and the server believes it. Every check above is therefore advisory: a caller can claim to be the supervisor and be treated as one. Before this model means anything, the role must come from an authenticated session, not from the client.

Tier 2 scoping is cosmetic. The console shows a Tier 2 analyst only their escalations, but that filter runs in the browser — the bootstrap response contains every case. Scoping has to move to the server before it is a confidentiality control.

Refusals are not audited. A 403 returns before anything is written to the audit log, so a repeated attempt to exceed authority leaves no trace. Denied attempts are usually more interesting than permitted ones.

Order to fix it in

Each step is worth doing alone, and the first one is worth more than the rest combined.

#	CHANGE	WHY THIS ORDER
1	Authenticate the session and take the role from it, never from the request body	Until this exists, every other permission is a suggestion
2	Check override, and gate /api/reset and /api/alerts	Closes the three ungarded write paths in the current build

#	CHANGE	WHY THIS ORDER
3	Move Tier 2's case scoping to the server	Makes the role a confidentiality boundary rather than a view
4	Write denied attempts to the audit log	Cheap, and it is the signal you most want
5	Add the SOC Manager role with config	Makes autonomy and the kill switches usable by someone
6	Add the Security Administrator with lessonApprove	Completes the learning loop, which currently dead-ends
7	Add Tier 3 with containment and case takeover	Needed before any wave carrying class C incidents goes live
8	Name the residual-risk owner	Playbook open item 10. Not an engineering task, and the only one that cannot be delegated

Permissions, endpoint behaviour and the current gaps are taken from the running code — ROLES and `can()` in `server.js`. Role responsibilities follow PB-T1-001 v0.10 and the decision authority matrix it inherits. Where this document and the code disagree, the code is what is running.

